

Documentation-Driven Threat Analysis

DermaTriage Extended Documentation Case Study

Annotated Holdout Study Through A5 Closure

Current research artifact

Repository baseline: 0e60754d21aa24ea487f3f60803b6b0cce8d2e2b. Methodology authority remains R4 unless this document explicitly states otherwise.

Indice

1	DermaTriage - Extended DDTA Documentation Case Study	2
1.1	1. Why this case study exists	2
1.2	2. Source set and evidence roles	2
1.3	3. A0 - Authority gate	2
1.3.1	Question	2
1.3.2	Result	3
1.3.3	Methodology lesson	3
1.4	4. A1 - From technology stack to project problem	3
1.4.1	Important unresolved boundary	3
1.5	5. A2 - MacroRequirement discovery	3
1.5.1	5.1 MR-01 versus MR-02	3
1.5.2	5.2 MR-03 versus MR-04	4
1.5.3	Methodology lesson	4
1.6	6. A3/A4 - MR-01: image fallback, P-scale and SLA	4
1.6.1	6.1 DEC-01 - no-image continuity	4
1.6.2	6.2 DEC-02 versus FR-02	4
1.6.3	6.3 SLA - precision without sufficiency	5
1.6.4	Methodology lesson	5
1.7	7. MR-03 - clinical review without stealing clinical authority	5
1.8	8. MR-04 - first major holdout pressure	5
1.9	9. DEC-04 - numeric neutralization and accumulation policy	6
1.9.1	Why hardcoding 10/50 in FRs was rejected	6
1.10	10. DEC-09 / FR-06 - policy versus window-size binding	6
1.10.1	Gap exposed	7
1.11	11. DEC-10 / FR-07 - semantic concept versus data-state encoding	7
1.11.1	Cross-MR gap	7
1.12	12. DEC-11 / FR-08 - transformation is not a parameter	7
1.12.1	Cross-MR ownership	7
1.13	13. DEC-06 / FR-09 - qualification is not deployment	8
1.14	14. DEC-07 - first non-security specialization pressure	8
1.14.1	Thesis-boundary lesson	8
1.15	15. The two 5% values - same literal, different semantics	8
1.16	16. DEC-08 / FR-10 - reversibility without inventing monitoring	9
1.17	17. DEC-05 cumulative review - why FR-11 was necessary	9

1.17.1	New high-confidence guide test	10
1.18	18. A5 cumulative closure	10
1.19	19. Methodology findings accumulated through A5	10
1.19.1	GI-13 - Numeric neutralization before parameter classification	10
1.19.2	GI-14 - Cross-MR/reference is not ownership	10
1.19.3	GI-21 - Information/realization bridge	10
1.19.4	GI-22 - Requirement identity versus number of clauses/test rows	11
1.19.5	GI-23 - Shared vocabulary does not prove cross-FR binding	11
1.19.6	GI-24 - Semantic parameter versus concrete binding	11
1.19.7	GI-25 - Parameter Governance Boundary	11
1.19.8	A5 counterexample test - candidate new guide rule	11
1.20	20. What the source documentation did well	11
1.21	21. What the source documentation leaves ambiguous	11
1.22	22. Security-related source evidence intentionally deferred	12
1.23	23. Why BA is still blocked	12
1.24	24. Next research steps	12
1.25	25. Core lesson of the holdout so far	13

1 DermaTriage - Extended DDTA Documentation Case Study

Status: ANNOTATED HOLDOUT STUDY / THROUGH A5 CLOSURE

Purpose: preserve the reasoning, rejected interpretations, gaps and methodology observations that must not contaminate the clean project documentation

Repository baseline: 0e60754d21aa24ea487f3f60803b6b0cce8d2e2b

Methodology authority: DDTA_DOCUMENTATION_BA_AUTHORING_GUIDE_R4

Source package SHA-256: E9ED2C507BEFB95F54A52084687CD1E8798863AE81CF69D09568864D8CBF280E

1.1 1. Why this case study exists

DermaTriage is used as a structurally different holdout after the Facial Access case. The goal is not to make DermaTriage look complete. The goal is to test whether DDTA can reconstruct governed project meaning from ordinary architecture/test/configuration documentation while:

- separating responsibility from technology;
- separating project commitments from current implementation;
- preserving source gaps;
- avoiding BA contamination;
- producing human-readable documentation that can later support security analysis.

The clean project candidate and this study are intentionally separate. The clean candidate answers **what the project currently governs**. This study answers **how and why that meaning was derived**.

1.2 2. Source set and evidence roles

Authoritative package:

DermaTriage-Docs-20260830T152637Z-1-001.zip

SHA-256:

E9ED2C507BEFB95F54A52084687CD1E8798863AE81CF69D09568864D8CBF280E

Contained artifacts:

- OR2_Architecture_Document.pdf - principal semantic source;
- OR2_Model_Test_Report.pdf - model/evaluation evidence;
- OR3_Dataset_Metadata_Catalog.pdf - dataset/privacy/current-data evidence;
- OR4_Training_Environment_Config.pdf - configuration/realization evidence;
- OR4_Training_Cycles_Report.pdf - retraining/evaluation/lifecycle evidence;
- OR5_Test_Environment_Setup.pdf - test/API/environment evidence;
- efficientnet_b4.pth - model artifact, realization evidence.

Old DDTA reconstructions and old BA artifacts were excluded from project-authority decisions.

1.3 3. A0 - Authority gate

1.3.1 Question

Which documents may define DermaTriage project meaning?

1.3.2 Result

The original package is authority. OR2 Architecture is the principal semantic source because it describes project purpose, pipeline, adaptation layer, external service interactions and self-learning loops. Tests/-training/configuration documents can corroborate or expose current realization but do not automatically convert implementation details into normative requirements.

1.3.3 Methodology lesson

A traditional architecture document often mixes:

project intention
current architecture
configuration
operational behavior
test evidence
historical snapshot

DDTA must classify those meanings before documenting them.

1.4 4. A1 - From technology stack to project problem

OR2 starts with a concrete stack: EfficientNet-B4, Qwen2-VL, ChromaDB, BioMistral, B4 integration and a four-stage pipeline.

A literal reconstruction would incorrectly make those technologies the project problem.

The stabilized framing instead became:

DermaTriage supports early triage of dermatological cases concerning potentially oncological skin lesions, using available case information to determine a priority of care and support routing toward appropriate specialist assistance.

1.4.1 Important unresolved boundary

The source includes pathology/diagnostic outputs, but the documentation does not sufficiently establish that DermaTriage owns definitive clinical diagnosis authority. That meaning remains explicitly unresolved rather than being hidden by generic wording.

1.5 5. A2 - MacroRequirement discovery

1.5.1 5.1 MR-01 versus MR-02

Source output bundles urgency/P-scale, specialist and SLA information. Co-location does not prove one responsibility.

Split test:

Can priority/urgency change independently from specialist destination?
YES.

Therefore:

- MR-01 owns triage urgency/priority;
- MR-02 owns specialist-oriented routing indication.

MR-02 later STOPS because the source does not define enough downstream routing semantics.

1.5.2 5.2 MR-03 versus MR-04

The source also bundles doctor review, prompt evolution and classifier retraining into a “self-learning” story.

Split test:

Can clinical validation exist without model adaptation? YES.

Can adaptation policy change while review capture remains stable? YES.

Therefore:

- MR-03 owns clinical-review result management;
- MR-04 owns controlled adaptation using accumulated review evidence.

MR-04 dependsOn MR-03 because adaptation consumes the clinical-review meaning.

1.5.3 Methodology lesson

A lifecycle narrative is not automatically one MacroRequirement. Split by autonomous responsibility, not by source heading.

1.6 6. A3/A4 - MR-01: image fallback, P-scale and SLA

1.6.1 6.1 DEC-01 - no-image continuity

Source evidence says that when no image is available, symptom-only scoring derives urgency from available B4 chatbot fields.

The material commitment surviving implementation substitution is:

image absence is not an absolute precondition for triage

This supports DEC-01 and then FR-01.

1.6.2 6.2 DEC-02 versus FR-02

Source table:

HIGH + confidence > 0.85	-> P1
HIGH	-> P2
MEDIUM	-> P3
LOW	-> P4

The Decision is not the entire table. The material project commitment is using P1-P4 as operational priority. The concrete conditional mapping is an operational obligation and therefore becomes FR-02.

This separation prevents a Decision from becoming a disguised algorithm table.

1.6.3 6.3 SLA - precision without sufficiency

The same source table lists 24h/48h/72h/7 days.

The review asked:

- what exactly must happen within the interval?
- when does the timer start?
- who owns compliance?
- is the number a maximum, target or recommendation?

The source does not establish those semantics sufficiently.

Disposition:

GAP-DERMA-SLA-01

NOT SPECIFIED

1.6.4 Methodology lesson

A number can be precise while its meaning is underspecified.

1.7 7. MR-03 - clinical review without stealing clinical authority

A naive formulation such as:

DermaTriage validates its diagnoses clinically

would incorrectly assign clinical judgment to the system.

The responsibility boundary established:

healthcare professional -> owns clinical judgment

DermaTriage -> records/correlates review result

DEC-03 therefore governs separation between original AI outcome and clinical review, while FR-03 governs recording/correlation and distinction between confirmation and correction.

The source field agrees was not promoted into FR-03 because a boolean implementation representation is not automatically the semantic definition of clinical review.

1.8 8. MR-04 - first major holdout pressure

The architecture describes:

- prompt evolution every 10 corrections;
- sliding window of 20 recent examples;
- classifier retraining after 50 disagreement corrections;
- agrees == False;
- P-scale to HIGH/MEDIUM/LOW label mapping;
- comparative acceptance criteria;
- rollback beyond 5% degradation;
- fine-tuning details.

Treating all of this as “continuous learning requirement” would create a monolithic and implementation-contaminated artifact.

The Decision family was therefore discovered before writing FRs.

1.9 9. DEC-04 - numeric neutralization and accumulation policy

Initial source phrasing:

```
Every 10 corrections -> prompt evolution
50 disagreement corrections -> classifier retraining
```

Neutralization:

```
10 -> N
50 -> N
```

What remains?

```
adaptation is not immediate per single review;
each path is activated after a governed accumulation condition is satisfied
```

That surviving strategy is DEC-04.

1.9.1 Why hardcoding 10/50 in FRs was rejected

An early FR wording used exact literals. Review showed that the source establishes current values but not their immutable normative status or change authority.

Correct pattern:

```
FR semantic rule
-> semantic threshold parameter N
-> current documented binding 10 or 50
-> realization configuration
```

This became the basis for the Parameter Governance Boundary.

1.10 10. DEC-09 / FR-06 - policy versus window-size binding

Source evidence says prompt evolution uses a sliding window of 20 most recent examples.

Neutralizing 20 -> N leaves a material policy:

```
use bounded recent evidence rather than unrestricted history
```

Therefore:

- DEC-09 owns the bounded-recent-evidence strategy;
- FR-06 operationalizes selection of a bounded sliding window;
- PromptEvidenceWindowSize=N is a semantic parameter;
- current binding N=20 is preserved without claiming immutable governance.

1.10.1 Gap exposed

The source does not fully define ordering, membership, underfill, overlap/reuse, deduplication or scope. These stay in GAP-DERMA-PROMPT-WINDOW-01.

1.11 11. DEC-10 / FR-07 - semantic concept versus data-state encoding

Source says classifier retraining uses corrections where:

```
agrees == False
```

The semantic question is not “must the field be named agrees?”. The stable meaning is:

```
clinical disagreement with the relevant AI outcome qualifies as classifier-adaptation evidence
```

Therefore:

```
ClinicianDisagreement  
  -> governed semantic concept
```

```
agrees == False  
  -> source-observed current data/state encoding
```

This was the first clear example of the bridge:

```
semantic concept -> data/state encoding
```

1.11.1 Cross-MR gap

MR-03 owns review-result semantics, while MR-04 owns its use as adaptation evidence. The exact relation among correction, disagreement and agrees is not fully defined, producing GAP-DERMA-REVIEW-DISAGREEMENT-BINDING-01.

1.12 12. DEC-11 / FR-08 - transformation is not a parameter

Source mapping:

```
P1 -> HIGH  
P2 -> HIGH  
P3 -> MEDIUM  
P4 -> LOW
```

Replacing HIGH/MEDIUM/LOW by generic variables would destroy the governed meaning. The mapping is therefore the functional transformation itself, not a configuration parameter.

This produced FR-08 as one coherent requirement with four normative clauses.

1.12.1 Cross-MR ownership

The P-scale domain belongs to MR-01. MR-04 consumes the corrected P-scale as classifier-supervision input. Consumption does not create a second parent and does not automatically establish MR-04 dependsOn MR-01.

1.13 13. DEC-06 / FR-09 - qualification is not deployment

Source evidence says a retrained candidate must satisfy comparative quality conditions before replacement.

FR-09 therefore produces a semantic result:

qualified for adoption

not:

automatically deployed

The source does not sufficiently govern final promotion authority. GAP-DERMA-DEPLOY-01 remains open.

This distinction prevents an evaluation gate from silently becoming production-deployment authority.

1.14 14. DEC-07 - first non-security specialization pressure

The source uses three asymmetric quality conditions:

sensitivity must not worsen

false-low must not worsen

accuracy may degrade only within a bounded tolerance

These do not define a new autonomous capability. They strengthen the acceptable satisfaction of FR-09.

A5 disposition:

NO NEW FR

ROUTE TO A7

The likely specialization meanings are:

- SensitivityNonDegradation;
- FalseLowNonDegradation;
- LimitedAccuracyDegradation.

1.14.1 Thesis-boundary lesson

This holdout confirms that SpecializedRequirement [abstract] was a sensible design: non-security specializations can exist. But the thesis is about security analysis over governed documentation. Therefore the quality meanings are preserved without opening a full QualityRequirement subtype research track.

1.15 15. The two 5% values - same literal, different semantics

The source reports 5% in two places:

- pre-adoption bounded accuracy degradation;

- post-adoption rollback trigger.

The review deliberately did not merge them.

```
AccuracyDegradationTolerance = T
RollbackAccuracyDegradationThreshold = R
```

```
current T = 5%
current R = 5%
```

```
T == R ? NOT ESTABLISHED
```

Lifecycle position and purpose define parameter identity, not literal equality.

The source also does not sufficiently establish whether 5% means relative percent or percentage points in the governed contract, even if current test documents perform a concrete calculation.

1.16 16. DEC-08 / FR-10 - reversibility without inventing monitoring

R4 stabilized DEC-08 as post-adoption reversibility.

The source currently describes “automatic rollback”, but that wording appears inside current realization/training documentation. The governed requirement extracted is therefore narrower:

an already adopted materially degrading classifier adaptation must be revocable by restoring a p

The review did **not** infer:

- continuous monitoring;
- hourly evaluation;
- automatic rollback as a permanent policy;
- admin approval;
- exact target-version algorithm.

Those meanings remain in GAP-DERMA-ROLLBACK-BINDING-01 unless later authority establishes them.

1.17 17. DEC-05 cumulative review - why FR-11 was necessary

At first it appeared that DEC-05 might STOP without its own FR because the prompt and classifier branches already had separate FRs.

Counterexample:

```
prompt threshold satisfied
-> system activates prompt evolution AND classifier adaptation

classifier threshold not satisfied
```

FR-04 can still pass. FR-05 can still pass whenever its own condition eventually occurs. Yet DEC-05 is violated because the paths are cross-triggered.

This demonstrates:

all current FRs pass
while Decision still fails

Therefore FR-11 was required to govern lifecycle independence.

1.17.1 New high-confidence guide test

Before STOP below a Decision ask:

Can all current downstream Requirements be satisfied while this Decision is still violated?

If yes, downstream coverage is incomplete.

1.18 18. A5 cumulative closure

Final FR set through A5:

FR	Parent	Meaning
FR-01	DEC-01	symptom-based urgency when image unavailable
FR-02	DEC-02	urgency/confidence -> P-scale mapping
FR-03	DEC-03	correlated clinical review distinct from original outcome
FR-04	DEC-04	prompt-path activation at semantic accumulation threshold
FR-05	DEC-04	classifier-path activation at semantic qualifying-evidence threshold
FR-06	DEC-09	bounded recent evidence for prompt evolution
FR-07	DEC-10	clinical disagreement qualification
FR-08	DEC-11	corrected P-scale -> classifier supervision target
FR-09	DEC-06	comparative pre-adoption qualification
FR-10	DEC-08	post-adoption rollback capability
FR-11	DEC-05	lifecycle independence between adaptation paths

DEC-07 routes to A7 rather than producing a fake FR.

A5 cumulative disposition:

PASS / CLOSED
A4 REOPEN: NO

1.19 19. Methodology findings accumulated through A5

1.19.1 GI-13 - Numeric neutralization before parameter classification

A concrete value should not determine document type merely because it is numeric.

1.19.2 GI-14 - Cross-MR/reference is not ownership

A requirement may consume governed meaning from another owner without a second parent.

1.19.3 GI-21 - Information/realization bridge

Observed bridge taxonomy:

semantic concept -> data/state encoding
semantic parameter -> configuration value
semantic reference -> interface identifier
semantic transformation -> realization encoding

1.19.4 GI-22 - Requirement identity versus number of clauses/test rows

One coherent obligation may contain multiple normative clauses and multiple test cases.

1.19.5 GI-23 - Shared vocabulary does not prove cross-FR binding

Lexical equality is not enough to establish producer/consumer identity.

1.19.6 GI-24 - Semantic parameter versus concrete binding

Preserve symbolic semantic parameter separately from current concrete value.

1.19.7 GI-25 - Parameter Governance Boundary

Semantic-owner and lifecycle classification must occur before deciding whether a numeric value belongs in the governed semantic layer.

1.19.8 A5 counterexample test - candidate new guide rule

Before Decision STOP, verify that the Decision cannot still be violated while all current descendants pass.

1.20 20. What the source documentation did well

DermaTriage source documentation contains unusually useful concrete evidence:

- explicit four-stage pipeline and adaptation layer;
- endpoint inventory;
- explicit fallback behavior;
- clinical-review endpoints;
- threshold/window values;
- label mapping;
- comparative quality criteria;
- rollback evidence;
- privacy/data-handling statements;
- test and training evidence.

This concreteness made semantic classification possible.

1.21 21. What the source documentation leaves ambiguous

The same documentation mixes stable project meaning with current implementation snapshot. Important examples:

- whether current numeric values are governed constants or configuration;
- whether deployment is automatic after qualification;
- exact acceptance and rollback quantitative semantics;

- complete clinical-review state model;
- specialist-routing semantics;
- SLA meaning;
- diagnostic authority;
- exact data/interface bindings and missing-value behavior.

DDTA adds value by making these boundaries explicit instead of hiding them inside prose/tables.

1.22 22. Security-related source evidence intentionally deferred

The source also contains:

- X-API-Key protection on many administrative endpoints;
- B4 JWT authentication;
- anonymized patient IDs in research data;
- no raw images in the RAG CSV;
- B4 patient uploads processed in memory and not permanently stored in the research dataset.

These facts are preserved for A8. They are not yet promoted in this study to final SecurityRequirements because the security-property scope and governance must be reviewed explicitly.

This preserves the thesis order:

```
document project meaning first
-> review existing governed security properties
-> close documentation
-> build BA
-> run STRIDE/STRIDE-AI
-> feed accepted security findings back through governance
```

1.23 23. Why BA is still blocked

The accepted DermaTriage BA must not begin until A12 promotion readiness passes. A limited pre-A7 consumer probe may later be used to test whether the BA can preserve generic specialization information, but it must not decide project meaning or document types.

1.24 24. Next research steps

```
A6 project-wide Requirement split
-> PRE-A7 scope + Documentation<->BA consistency check
-> A7 specialization review
    -> preserve non-security specializations outside thesis subtype scope
-> A8 existing governed SecurityRequirement review
-> A9 cross-MR
-> A10 terminology/bindings
-> A11 regression
-> A12 promotion
-> accepted DermaTriage BA
-> BA stabilization/regression
-> STRIDE / STRIDE-AI
-> governed security feedback cycle
```

1.25 25. Core lesson of the holdout so far

The most useful result is not that DDTA can restate the architecture document. It is that the method repeatedly separates four things that ordinary documentation tends to mix:

- what must remain true for project meaning to remain the same
- what is a current concrete binding
- what is current realization evidence
- what is genuinely not specified

That separation is what makes the later Base Analysis and security analysis traceable without allowing the analysis method to rewrite project truth.